

AI Governance Policy

Progress Learning

Document Type: AI Governance Policy

Effective Date:

Last Reviewed:

Policy Owner:

Approved By: Executive Management, Security Team, IT, & AI Program Manager

1. Purpose and Scope

This AI Usage Policy establishes the framework for secure, ethical, and compliant use of Generative AI (Gen AI) tools and Large Language Models (LLMs) at Progress Learning. This policy applies to all employees, contractors, and relevant third parties who interact with AI systems in the course of their work.

As an EdTech company committed to protecting student data and maintaining SOC 2 compliance, Progress Learning recognizes both the opportunities and risks associated with AI technologies. This policy ensures that AI systems are deployed and used in a manner that protects sensitive information, maintains regulatory compliance, and solidifies our strict security and privacy posture.

2. Policy Governance

2.1 Formalization and Documentation

The AI Usage Policy shall be formally documented, widely published, and mandated for all employees, contractors, and relevant third parties. The policy must be readily accessible through the company's internal knowledge management systems.

2.2 Policy Review and Updates

Annual Review: The policy will be reviewed and approved by management and relevant stakeholders (Executive Management, Security Team, IT, & AI Program Manager) at least annually.

Event-Driven Updates: The policy will be updated immediately upon identification of:

- Significant changes in regulatory requirements (e.g., data privacy laws, sector-specific regulations, AI governance frameworks)
- Material changes in internal AI technology usage or capabilities
- Security incidents or vulnerabilities related to AI systems
- Changes in customer or vendor contractual obligations

2.3 Stakeholder Approval

All policy updates must receive formal approval from:

- Executive Management
- Legal Department
- Information Security Team
- IT Department
- Compliance Officer

3. Data Protection and Privacy

3.1 Prohibited Data Use

Strict Prohibition: Employees are strictly prohibited from inputting the following data types into any external or third-party Large Language Models (LLMs) or Gen AI tools:

- Personally Identifiable Information (PII)
- Sensitive student data
- Sensitive employee data
- Student educational records
- Authentication credentials

Employee Responsibility: All staff must be trained to recognize and redact PII and sensitive information before utilizing AI tools. When in doubt, employees should consult with their manager or the Security team.

3.2 Student Data Protection and Regulatory Compliance

FERPA and COPPA Compliance: In adherence to the Family Educational Rights and Privacy Act (FERPA) and Children's Online Privacy Protection Act (COPPA), student data shall never be utilized, processed, or accessed by any Generative AI or LLM systems, whether internal or external.

Data Segregation: Strict technical and procedural controls must be maintained to segregate and protect student data from all AI environments. This includes:

- Network segmentation to isolate student data systems
- Access controls that prevent AI systems from querying student databases
- Regular audits to verify data segregation effectiveness
- Incident response procedures specific to potential AI-related student data exposure

3.3 Customer-Facing AI Systems

Agentforce and Similar Tools: All customer-facing AI implementations (including but not limited to Agentforce via Salesforce) must adhere to the following requirements:

- **Knowledge Source Restriction:** AI systems must be grounded exclusively in approved, customer-facing knowledge sources such as Help Center articles, public documentation, and approved FAQ databases
- **PII Training Prohibition:** Customer-facing AI must not be trained on any PII or sensitive customer information
- **Secure Data Flow:** Data flow must be managed securely through designated, approved platforms (e.g., Salesforce Data Cloud) that leverage appropriate trust and security layers
- **Human Review:** All AI-generated customer communications must follow the Human-in-the-Loop requirements outlined in Section 4

4. Human Oversight and Accountability

4.1 Human-in-the-Loop Principle

Mandatory Oversight: Adherence to the Human-in-the-Loop principle is mandatory for all uses of Gen AI outputs, with particular emphasis on customer-facing roles and business-critical decisions.

4.2 Review and Approval Requirements

Pre-Deployment Review: Automated decisions or external communications generated by AI must be reviewed and approved by a trained staff member before deployment or transmission.

Qualified Reviewers: Only employees who have completed mandatory AI usage training are authorized to review and approve AI-generated content for external use.

Documentation: Reviews and approvals should be documented in accordance with company record-keeping policies, particularly for customer-facing communications and significant business decisions.

5. Access Control and Infrastructure Security

5.1 Role-Based Access Control (RBAC)

Implementation: Progress Learning implements and enforces Role-Based Access Control (RBAC) for all environments, databases, and systems that store LLM data, model weights, or related infrastructure.

Least Privilege Principle: Access must be granted based on the principle of least privilege, ensuring administrators and developers only have the permissions necessary for their specific roles and responsibilities.

Access Review: User access rights must be reviewed quarterly and immediately upon role changes or termination.

5.2 Administrator Security

Specialized Training: Mandatory, specialized security training must be provided to all administrators and engineers responsible for managing LLM-based systems. Training must cover:

- Best practices for environment hardening
- Vulnerability identification and patching procedures
- Secure management of access keys and credentials
- Secure configuration and deployment practices
- Incident response for AI-specific security events

Administrative Access Logging: All administrative actions within LLM-based systems must be logged and monitored.

5.3 Logging and Monitoring

Comprehensive Logging: Establish comprehensive logging and monitoring of all access and activities within LLM-based systems, including:

- User authentication and access attempts
- Administrative actions and configuration changes
- Data access and query patterns
- Model inference requests and responses
- System performance and error conditions

Security Alerting: Alerts must be configured and actively monitored for:

- Suspicious activity or access patterns
- Excessive data queries or downloads
- Unauthorized configuration changes
- Failed authentication attempts
- Unusual model behavior or outputs

Log Retention: Logs must be retained in accordance with SOC 2 requirements and company data retention policies, with a minimum retention period of one year.

6. Model Development and Deployment

6.1 LLM Training Data Management (Future State)

When internal LLM models are developed, a formal data governance process must be implemented to manage training data:

Licensing and Rights Verification:

- All training datasets must be reviewed and approved by Legal before use
- Appropriate licenses and usage rights must be verified and documented
- Documentation must be maintained for audit purposes

Access Controls:

- Implement least privilege access controls (LPAC) to limit training data access only to authorized personnel
- Maintain an access log for all training data repositories

Data Encryption:

- All stored training data must be protected using industry-approved encryption algorithms (e.g., AES-256)
- Encryption must be applied both at rest and in transit
- Encryption key management must follow company cryptographic standards

6.2 Pre-Deployment Vetting

Risk Assessment Requirement: A formal Risk Assessment and Vetting Process must be completed for all new or updated LLM models and AI systems prior to deployment into the organization's production environment.

Assessment Components: The risk assessment must include:

- Security vulnerability analysis
- Data privacy impact assessment
- Regulatory compliance review
- Operational risk evaluation
- Business impact analysis

6.3 Security Testing

Mandatory Testing: All AI models and systems must undergo security testing prior to deployment. Testing must specifically address:

Model Inversion Attacks: Evaluate the risk of attackers extracting training data through carefully crafted queries

Prompt Injection and Jailbreaking: Test the model's resilience against attempts to manipulate output or bypass safety constraints

Denial of Service (DoS) Vectors: Assess vulnerability to resource exhaustion or availability attacks

Additional Testing: Consider other relevant security tests based on the specific AI system's architecture and use case.

6.4 License and Legal Risk Review

Legal Compliance Review: Legal counsel and IT/Security must review all models and their training data to confirm:

License Compliance:

- Adherence to all open-source licenses
- Compliance with commercial terms of service
- Proper attribution where required

Intellectual Property Protection:

- Mitigation of potential copyright infringement risks
- Assessment of intellectual property risks from model outputs
- Documentation of IP clearance procedures *

Regulatory Compliance:

- Compliance with data privacy regulations (CCPA, FERPA, COPPA)
- Adherence to sector-specific AI governance requirements
- Alignment with SOC 2 control objectives

6.5 Acceptance Criteria

Deployment Authorization: Models will only be approved for deployment once:

- All identified security vulnerabilities are remediated or mitigated to an acceptable risk level
- All legal and compliance risks are formally documented and accepted by executive management
- Required approvals are obtained from Security, Legal, and IT leadership
- Documentation is complete and audit-ready

7. Training and Education

7.1 Mandatory Employee Training

Training Requirements: All employees, contractors, and relevant third parties must complete mandatory training on the proper, secure, and ethical use of Gen AI tools.

Training Content: Training must cover:

- Proper use cases for AI tools
- Prohibited uses, particularly regarding PII and sensitive data
- Data classification and handling procedures
- Security best practices for AI tool usage
- Incident reporting procedures
- Ethical considerations in AI usage

Training Schedule:

- Upon hiring or onboarding
- At least annually thereafter
- Upon significant policy updates
- Following security incidents involving AI systems

Training Platform: Utilize platforms such as KnowBe4 or equivalent systems to deliver and track specialized security training.

Compliance Tracking: Training completion must be tracked and reported to management at least annually. The Information Security Team will perform an internal review and reporting cycle quarterly to ensure compliance and timely remediation of non-compliant employees.

7.2 Role-Specific Training

AI Reviewers: Employees responsible for reviewing AI-generated content must receive additional training on:

- Quality assessment criteria
- Bias detection and mitigation
- Fact-checking and verification procedures
- Legal and compliance considerations

Technical Staff: Additional technical training requirements are outlined in Section 5.2.

8. Compliance and Enforcement

8.1 Policy Violations

Violations of this policy may result in disciplinary action, up to and including termination of employment or contract. Serious violations may also result in legal action.

8.2 Reporting Obligations

Incident Reporting: All employees must immediately report:

- Suspected policy violations
- Security incidents involving AI systems
- Unintended disclosure of sensitive information to AI systems
- Unusual AI system behavior or outputs

Reporting Channels: Reports should be submitted through:

- Direct supervisor or manager
- Security team (security@progresslearning.com)
- Human Resources

8.3 Audit and Assessment

Internal Audits: Regular internal audits will be conducted to assess compliance with this policy as part of the SOC 2 compliance program.

External Audits: This policy and related controls will be reviewed during SOC 2 audits and other security assessments.

Continuous Improvement: Findings from audits will be used to improve controls and update this policy as necessary.

9. Definitions

Generative AI (Gen AI): AI systems capable of generating text, images, code, or other content based on input prompts.

Large Language Model (LLM): A type of AI model trained on large amounts of text data to understand and generate human-like text.

Personally Identifiable Information (PII): Any information that can be used to identify an individual, including but not limited to names, addresses, phone numbers, email addresses, and student IDs.

Human-in-the-Loop: A design pattern requiring human review and approval of AI outputs when training or integrated into workflows before they are acted upon or published.

FERPA: Family Educational Rights and Privacy Act - federal law protecting student education records.

COPPA: Children's Online Privacy Protection Act - federal law protecting online privacy of children under 13.

10. Document Control

Version History:

Date	Reviewer	Notes
10/20/2025	DaCota Cole	Document created
06/01/2026	DaCota Cole	Reviewed
6/12/2026	DaCota Cole	Updated prohibited data use policy

Review Schedule: Semiannual review required, next review date: 12/12/2026

Distribution: All employees, contractors, and relevant third parties

Questions: Contact the Information Security team at siteops@progresslearning.com

This policy is maintained by Progress Learning's Information Security Department and is subject to change. Employees are responsible for reviewing the current version of this policy regularly.